

Ambitionz Rebirth

Roadmap de **Hardening Industrial** — falhas, brechas e o backlog pontuado

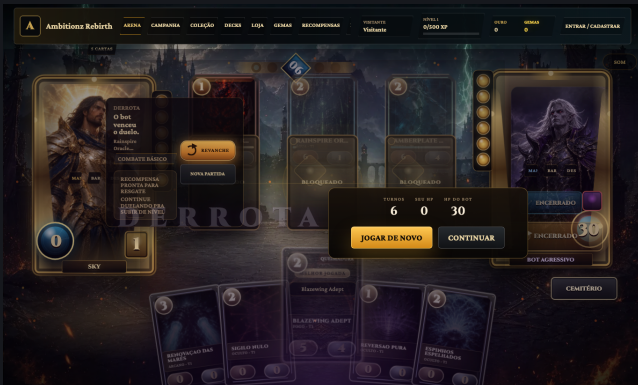
Caça a falhas e brechas no código vivo, cruzada com quatro auditorias internas (mai-jun/2026), a suíte real (1318 passed) e uma partida jogada com olhos de jogador. Inclui o que já foi pontuado e **resolvido** e, em destaque, o que foi pontuado e **ainda não fizemos**.

15 de junho de 2026 · documento de engenharia + produção



Eixo	Veredito industrial
Correção & segurança	Bons fechamentos recentes. Resta rate limit fora de auth e backup pré-migração.
Escala	Teto rígido: gunicorn -w 1 + MATCH_STORE em memória. Não sobe worker sem perder partida.
Dívida estrutural	Regrediu: css 15,6k / js 4,7k / persistence 3,2k / app 2,5k / engine 2,5k LOC.
Conteúdo	Arte própria 20/103 (meta pontuada 52 → 80%). Maior risco de retenção.
Legibilidade/feel	P0 de board vazio + jargão de engine na UI ainda presentes.
Observabilidade	Sentry só erros; falta logging estruturado e funil D1/D7 com dado real.

2 · Método e evidência



3 · Já pontuado e RESOLVIDO (não repetir)

Para dar crédito e evitar retrabalho: achados de auditorias anteriores que o código de hoje comprova como fechados.

Achado pontuado	Status hoje (evidência)	Sev
Colisão de match_id de convidado (vazava estado)	Resolvido — seed única por partida (rebirth_state.py:39, secrets.token_hex).	FEITO
Bot sempre 'defensive' p/ convidado	Resolvido por consequência (seed única faz a personalidade variar).	FEITO
~6 000 LOC zumbi + 14 MB backups	Removido — battle_engine_v2/card_effect_resolver/backups não existem mais.	FEITO
'100 vs 103 cartas' exposto ao jogador	Resolvido — len(catalog_payload()) (rebirth_product.py:183).	FEITO
CSRF ausente em /api/labs/fusion	Resolvido — coberto pelo gate (pós-Sprint 1).	FEITO
Anti-injeção por denylist frágil	Resolvido — allowlist (COMBAT_PAYLOAD_ALLOWED_FIELDS, app.py:744).	FEITO
Acentos faltando em erros (UI)	Resolvido — strings sem acento não encontradas.	FEITO
Sem CSP / sem compressão	Resolvido — Content-Security-Policy (app.py:850) + Flask-Compress (app.py:83).	FEITO
Sem SDK de erro	Integrado — sentry_sdk.init gated por SENTRY_DSN (app.py:148).	FEITO
Rate limit só em login	Ampliado p/ register/resent/login/change-password (ainda não cobre jogo).	PARCIAL
Cerimônia de fim inexistente (P1.3)	Melhorou — painel de derrota com stats e CTAs; ainda discreta.	PARCIAL

4 · Pontuado e NÃO FEITO (backlog pendente)

O coração do pedido: evoluções já registradas nos docs/auditorias que seguem em aberto.

Item pendente	Onde foi pontuado	Sev
Multi-worker readiness: extrair MATCH_STORE de memória (gunicorn -w 1)	FULLSTACK \$2.3 / BRUTAL \$4.2 / AAA	CRÍTICO
Modularizar engine/persistence/app/js/css (e quebrar resolve_turn 270L, _apply_trap_effect 210L)	FULLSTACK \$2.2 / STUDIO P2.5 / AAA P1	CRÍTICO
Arte própria 20→52→80% do catálogo	FULLSTACK \$1.3 / BRUTAL \$3.5	ALTO
P0.1: jogador casual termina com 2+ unidades e ~50% WR sem jogar otimizado	PLAYER_EYES P0.1 (revalidar)	ALTO
simulate_balance dirigir pelo dispatcher real (balance hoje é cego)	STUDIO P1.3 / FULLSTACK \$1.7	ALTO
Loop diário com payoff: quests no fluxo, mastery por carta, conquistas narrativas	FULLSTACK \$3.3 / STUDIO Sprint 5	ALTO
Dashboard D1/D7 por user×dia (telemetria humana real)	FULLSTACK \$4.1 / AAA Fase 5	ALTO
Rate limit em /start, /attack, /next-turn, /telemetry, /beacon (scraping)	FULLSTACK \$5.2	MÉDIO
Backup automatizado de Postgres antes da migração de deploy	FULLSTACK \$5.2 / AAA Fase 0	MÉDIO
Logging estruturado (request_id/user_id/match_id) + APM + alerting	FULLSTACK \$5.2	MÉDIO
Painel de resultado: hierarquia + esconder jargão CADEIA EVENT-xxxxxx (rebirth.js:3106)	STUDIO P2.3 / BRUTAL \$1.3	MÉDIO
Tunar cartas: Scorchscale Imp (WR 0.71), 6 low-impact, 3 dead-hand, earth_counter (0.02)	STUDIO P2.7 / BRUTAL \$2.5	MÉDIO
'Protegido no turno 1' em slot vazio (rebirth.js:2692)	BRUTAL \$3.2	BAIXO
Reveal de booster com dopamina (P1.2)	PLAYER_EYES P1.2	BAIXO
Nomes de carta truncados no campo + overflow de mão (mobile)	PLAYER_EYES P2	BAIXO
Load testing (k6/Locust) + SLO p95 < 500 ms	FULLSTACK \$6 Sprint 6	BAIXO
max_chain_events 16 > alvo 15 (legibilidade)	STUDIO P2.8	BAIXO

5 · Regressão da dívida estrutural (pontuado, e piorou)

A modularização foi pontuada como P1 em três auditorias. Não só não aconteceu — os cinco arquivos-gigante **cresceram** desde a medição de 27/mai. Cada feature nova paga juros sobre essa dívida.

Arquivo	27/mai	Hoje	Variação
static/css/rebirth.css	9 282	15 602	+68%
static/js/rebirth.js	3 259	4 712	+45%
app.py	1 586	2 553	+61%
services/rebirth_engine.py	1 858	2 498	+34%
services/rebirth_persistence.py	2 651	3 214	+21%

Leitura: a trava de contrato (test_rebirth_frontend_contract.py) e o replay determinístico tornam o split **seguro** — dá para extrair módulos sem mudar comportamento. O custo de adiar é o risco de regressão subir a cada feature.

6 · Falhas/brechas reconfirmadas agora

- **Board vazio no feel casual (P0.1).** Jogando sem otimizar, perdi 30→0 travado vários turnos enquanto o bot acumulava 3 corpos. Foi mexido em v102, mas o sintoma reaparece — precisa de revalidação com harness casual, não com o lab otimizado.
- **Escala bloqueada.** render.yaml e procfile fixam `-w 1 --threads 100`; MATCH_STORE e os relógios de telemetria são dicts em memória. Subir worker hoje perde partidas.
- **Balance cego.** simulate_balance ainda chama o engine direto, não o dispatcher — ajustes de heurística não se refletem como em produção (achado P1.3, ainda aberto).
- **Jargão de engine vazando na UI.** 'CADEIA EVENT-0...' e termos de cadeia ainda aparecem no painel (rebirth.js:3106) — ruído para jogador novo.
- **Superfície aberta a scraping.** rotas de jogo e telemetria sem rate limit; só auth é protegido (app.py:541).

7 · Roadmap de hardening por trilhas

Trilha 1

Escala & confiabilidade

Objetivo. Sair do teto single-worker sem perder partida e tornar o deploy à prova de falha.

Itens

- Extrair MATCH_STORE para cache pluggável (memória / Redis / rehidratação Postgres) — o command/event log já permite reconstruir.
- Migrar para -w 2+ atrás de verificação; relógios de telemetria compartilhados.
- Backup automatizado de Postgres antes da migração; plano de rollback escrito.
- Load test (k6/Locust) com SLO p95 < 500 ms e alerting de error-rate.

Onde. render.yaml / procfile; app.py (MATCH_STORE, MATCH_TELEMETRY_CLOCKS); novo rebirth_match_cache.py; rebirth_schema.py.

Critério de saída. 100–500 usuários por uma semana sem fix manual de DB; restore drill repetível; match sobrevive a restart de worker.

Trilha 2

Dívida estrutural

Objetivo. Reverter a regressão dos arquivos-gigante com segurança de contrato.

Itens

- Quebrar resolve_turn (270L) e _apply_trap_effect (210L) em unidades testáveis.
- Split de rebirth_persistence em repos por domínio (schema/match/user/economy/telemetria).
- app.py em Blueprints (arena/conta/produto/economia/suporte/ops).
- Modularizar rebirth.js (API/store/renderers/tactics/motion) e rebirth.css por domínio.

Onde. rebirth_engine.py, rebirth_persistence.py, app.py, static/js/rebirth.js, static/css/rebirth.css.

Critério de saída. Nenhum módulo acima do limite acordado; replay e frontend contract verdes a cada extração; sem mudança de comportamento.

Trilha 3

Observabilidade & dados

Objetivo. Enxergar o jogo real para decidir com fato, não com palpite.

Itens

- Logging estruturado com request_id/user_id/match_id correlacionados; APM.
- Funil de primeira sessão e dashboard D1/D7 por user×dia (não por bot_profile).
- Alerting (error-rate, schema health, latência) e status page pública.

Onde. app.py (middleware de request), rebirth_telemetry.py, rebirth_live_balance.py, tools/rebirth_telemetry_analyzer.py.

Critério de saída. D1/D7 medidos (mesmo que ruins); causa de erro rastreável por id; abandono por turno visível.

Trilha 4

Balanço honesto

Objetivo. Fechar a cegueira do simulador e limpar o catálogo com dado.

Itens

- Fazer `simulate_balance` dirigir pelo dispatcher real (paridade com produção).
- Watchlist automática em CI (PR que tira carta da janela alerta).
- Tunar Scorchscale Imp (0.71), 6 low-impact, 3 dead-hand e `earth_counter` — só após telemetria humana (~500 partidas).

Onde. `services/rebirth_balance.py`, `rebirth_dispatcher.py`, `rebirth_cards.py` (`_monster_cost`), CI.

Critério de saída. Heurística do bot move o win-rate como em produção; nenhuma carta fora da janela sem alerta; patch versionado e reversível.

Trilha 5

Legibilidade & feel

Objetivo. Tornar a partida compreensível e justa para o jogador casual.

Itens

- Revalidar P0.1 (board vazio) com harness casual; garantir 2+ unidades vivas e ~50% WR sem otimizar.
- Hierarquizar painel de resultado (headline → delta → causa → detalhes) e esconder o jargão de cadeia.
- Corrigir 'Protegido no turno 1' em slot vazio; tooltip fora da carta; nomes legíveis no campo.
- Reforçar cerimônia de fim e adicionar reveal de booster.

Onde. `static/js/rebirth.js` (painel, slots, tactics), `rebirth_recap.js`, `rebirth_postmatch.py`, `static/css/rebirth.css`.

Critério de saída. Sessão olhos-de-jogador (desktop+mobile) aprova; <10% pedem ajuda antes do 1º summon.

Trilha 6

Conteúdo & arte

Objetivo. Fechar o débito de arte, principal risco de retenção.

Itens

- Pipeline de produção priorizando starter + cartas mais jogadas + lendárias + chefes de campanha.
- Metas escalonadas: 52/103 (50%) → 80% → 100% bespoke.
- Content validator cobrindo cobertura de arte e metadados antes de cada carta entrar.

Onde. `static/assets/rebirth/cards/`, `services/rebirth_art.py`, `rebirth_content_pipeline.py`, `manifest`.

Critério de saída. Toda carta de primeira sessão e toda lendária com arte própria; coleção deixa de parecer incompleta.

Trilha 7

Segurança & compliance

Objetivo. Fechar as brechas baratas de produção.

Itens

- Rate limit em `/start`, `/attack`, `/next-turn`, `/telemetry` e `/beacon`.
- Views de audit log de admin (a tabela já existe).
- Revisar CSP para produção (hoje pragmático/local) e cobertura de gate de backup-restore.

Onde. `app.py` (rate limit, headers), `rebirth_persistence.py` (`admin_audit_log`), `rebirth_beta_ops.py`.

Critério de saída. Nenhuma rota mutante sem limite; ações de admin auditáveis; CSP de produção sem inline desnecessário.

8 · Sequenciamento por portões

Portão	Foco	Entra quando	Critério de saída
A — Beta ampliada	Trilha 1 + P0.1 (T5) + backup + rate limit jogo (T7)	Antes de convidar mais testers	Worker-ready, board justo no casual, deploy com backup, rotas mutantes com limite.
B — Público controlado	Trilha 2 + 3 + 4 + arte 50% (T6)	Antes de abrir ao público	Arquivos dentro do limite, D1/D7 medidos, balance honesto, observabilidade viva.
C — Live / PvP	reconnect durável + arte 80% + live config	Depois de retenção provada	Match replayável server-side, SLO de carga, hotfix de balance sem deploy.

Os portões herdam os critérios já escritos no roadmap AAA (Fases 0/5/7–9); este documento os concretiza com os achados de código de hoje.

9 · Top 5 ações imediatas

#	Ação	Por quê agora
1	Extrair MATCH_STORE → cache pluggável	Destrava multi-worker — o teto industrial #1. Sem isso, escala é impossível.
2	simulate_balance via dispatcher real	Destrava toda a Trilha 4: hoje qualquer tuning de balance é escolha-cega.
3	Split de resolve_turn / _apply_trap_effect	Reduz risco de regressão e destrava novas mecânicas com segurança.
4	Revalidar P0.1 com harness casual	É a falha que eu vivi hoje (30→0 travado); ataca a retenção na raiz.
5	Backup pré-migração + rate limit em /start	Duas brechas de produção baratas e de alto impacto de risco.

Resumo de uma linha: o produto já fechou os bugs que *quebravam* partidas; o nível industrial agora é **escala, dívida estrutural, dado honesto e arte** — execução disciplinada, sem reescrita, atrás dos guard-rails que já temos.